

SQL Injection Pattern Matching Guidelines for Software Developers
Date: 1/20/2016

Version 3.0

SQL Injection Pattern Matching Guidelines For Software Developers

Document Control

Date	Version	Author	Action	Change Description
10/30/2015	1.0	IRS	Initial Version	
12/28/2015	2.0	IRS	Removed Double Dash (--) trigger	Double Dashes are no longer part of the SQL-I pattern checks.
1/20/2016	3.0	IRS	Updated keyword pattern based on latest changes.	Updated keywords pattern and removed the keywords listed on each row (rows 2-20) and consolidated them on one row which makes for a more readable document.

SQL Injection Pattern Matching Guidelines For Software Developers

1 Introduction

The IRS is deploying additional measures that Software Developers must implement to access the portal for Processing Year 2016 (Tax Year 2015). This document provides guidance patterns and examples of XML strings that may be rejected by the IRS. The information contained in this document should be treated as confidential and should not be widely distributed within your organization. The pattern information is provided for programming purposes only and should not be contained in any software messaging that is relayed back to end users.

2 Pattern Classes

The main pattern IRS rejects consists of an apostrophe or a quote, optionally followed by white space and/or parentheses, followed by an SQL keyword followed by a whitespace or any punctuation character. The SQL keywords IRS checks for include SQL operators such as "AND" and "OR" as well as SQL verbs such as "DROP", "DELETE", "INSERT", and "SELECT". IRS also reject on the slash-star comment delimiter, and on semicolons right after apostrophes or quotes. This list is not exhaustive, and may change over time. The alphabetic SQL keywords, whether operators or verbs, will be recognized only when followed by a whitespace character (including at least space and horizontal tab), a punctuation mark, or an entity reference to one of those. They will NOT be recognized when followed by either another letter or a decimal digit.

Please note that we do resolve all entity references, including Hex or Decimal references before the pattern matching. For example the following examples all resolve to double quotes (")

"

&x22;

"

The following table provides a description of the patterns and examples of the strings that would be rejected.

No	Pattern	Description	Example
1.	(?i)["]\s*<KEYWORD>[\s\p{Punct}]	Apostrophe or quotation followed by optional whitespace and the KEYWORD (case insensitive) followed by whitespace or any Punctuation character For a list of KEYWORDS please refer to Section 3 below this table.	Using AND as a keyword <xmlElement>' and </xmlElement> <xmlElement>' And </xmlElement> <xmlElement>' AnD </xmlElement> <xmlElement>'anD </xmlElement> <xmlElement>"and </xmlElement> <xmlElement>" And</xmlElement> <xmlElement>" AnD </xmlElement> <xmlElement>"anD </xmlElement> <xmlElement>' and.</xmlElement> <xmlElement>' And.</xmlElement> <xmlElement>' AnD.</xmlElement> <xmlElement>' and.</xmlElement>

SQL Injection Pattern Matching Guidelines For Software Developers

No	Pattern	Description	Example
			<xmlElement>" and.</xmlElement> <xmlElement>" And.</xmlElement> <xmlElement>" AnD.</xmlElement> <xmlElement>&quot; and.</xmlElement> <xmlElement>' and;</xmlElement> <xmlElement>' And&amp;</xmlElement> <xmlElement>" AnD&amp;</xmlElement> <xmlElement>&apos; and&amp;</xmlElement>
2.	(?i)['"]\s*;	Apostrophe or quotation followed by optional whitespace and the semi-colon character ";" (case insensitive)	<xmlElement>'</xmlElement> <xmlElement>'</xmlElement> <xmlElement>&apos;;</xmlElement> <xmlElement>&apos;&x3B;</xmlElement> <xmlElement>&apos;&#0059;</xmlElement> <xmlElement>"</xmlElement> <xmlElement>"</xmlElement> <xmlElement>&quot;;</xmlElement> <xmlElement>&quot;&x3B;</xmlElement> <xmlElement>&quot;&#0059;</xmlElement>
3.	/*	Slash followed by asterisk (C-language and SQL comment)	Joe /* ignored trailing delimiters

3 Keyword List

INSERT, UNION, SELECT, DELETE, DISTINCT, HAVING, TRUNCATE, REPLACE, HANDLER, LIKE, PROCEDURE, LIMIT, DROP, DUAL, CREATE, ALTER, OR, AND, NOT

4 Appendix

ASCII Decimal, Hex, Symbol Conversion Table: These values will be decoded and rejected if the resolved values form the defined SQL expression patterns

Dec	Hex	Symbol
32	20	(space)
33	21	!
34	22	"
35	23	#
36	24	\$
37	25	%
38	26	&

Dec	Hex	Symbol
63	3F	?
64	40	@
65	41	A
66	42	B
67	43	C
68	44	D
69	45	E

Dec	Hex	Symbol
94	5E	^
95	5F	_
96	60	`
97	61	a
98	62	b
99	63	c
100	64	d

SQL Injection Pattern Matching Guidelines For Software Developers

39	27	'
40	28	(
41	29	)
42	2A	*
43	2B	+
44	2C	,
45	2D	-
46	2E	.
47	2F	/
48	30	0
49	31	1
50	32	2
51	33	3
52	34	4
53	35	5
54	36	6
55	37	7
56	38	8
57	39	9
58	3A	:
59	3B	;
60	3C	<
61	3D	=
62	3E	>

70	46	F
71	47	G
72	48	H
73	49	I
74	4A	J
75	4B	K
76	4C	L
77	4D	M
78	4E	N
79	4F	O
80	50	P
81	51	Q
82	52	R
83	53	S
84	54	T
85	55	U
86	56	V
87	57	W
88	58	X
89	59	Y
90	5A	Z
91	5B	[
92	5C	\
93	5D	]

101	65	e
102	66	f
103	67	g
104	68	h
105	69	i
106	6A	j
107	6B	k
108	6C	l
109	6D	m
110	6E	n
111	6F	o
112	70	p
113	71	q
114	72	r
115	73	s
116	74	t
117	75	u
118	76	v
119	77	w
120	78	x
121	79	y
122	7A	z
123	7B	{
124	7C	
125	7D	}